

Lab 3b: Advanced Cybersecurity Risk Quantification

Student Name: Najma Abdi Omar

Reg. No: 2025/GRC/10331

Date: 04/10/2025

SecureBank Financial

Phase 1: Risk Exposure Calculation

Task 1: Calculate Annualized Loss Expectancy (ALE)

For each vulnerability, calculate:

- Single Loss Expectancy (SLE)
- Annual Rate of Occurrence (ARO)
- Annualized Loss Expectancy (ALE)

Answer:

$ALE = SLE \times ARO$

ALE 1: API Authentication Bypass

ARO= Exploit Probability = 15% = 0.15

SLE= Maximum Single Incident Loss= \$5,000,000

ALE= \$5,000,000 x 0.15=\$750,000

ALE 2: Database Injection Vulnerability

ARO= 25%=0.25

SLE= (Record at Risk X Cost per Record) = (500,000 x \$250) =\$125,000,000

ALE= \$125,000,000 X 0.25 = \$31,250,000

ALE 3: Session Hijacking

ARO= 40% = 0.40

SLE= 5000 X \$1500= \$7,500,000

ALE= \$7,500,000 X 0.40 = \$3,000,000

Summary Table:

Vulnerability	SLE (\$)	ARO	ALE(\$)
API AUTHENTICATION BYPASS	5,000,000	0.15	750,000
DATABASE INJECTION	125,000,000	0.25	31,250,000
SESSION HIJACKING	7,500,000	0.40	3,000,000

Task 2: Prioritize Risks

Create a risk matrix showing:

- Vulnerability
- SLE
- ARO
- ALE
- Risk Priority Level

Answer:

To get the answer to this task we use our calculated values from the previous task, assign priority based on the vulnerability and calculated based on the ARO and ALE.

We have factored the calculations using:

Likelihood based on ARO ranges: (0.01- 0.10: **Very Low**, 0.11-0.25 **Low**, 0.26-0.40 **Medium**, 0.41-0.60 **High**, >0.60 **Critical**)

Impact Based on the ALE Ranges: <\$1M **Very Low**, \$1M-\$5M **Low**, \$5M-\$10M **Medium**, \$10M-\$25M **High**, >\$25M **Critical**

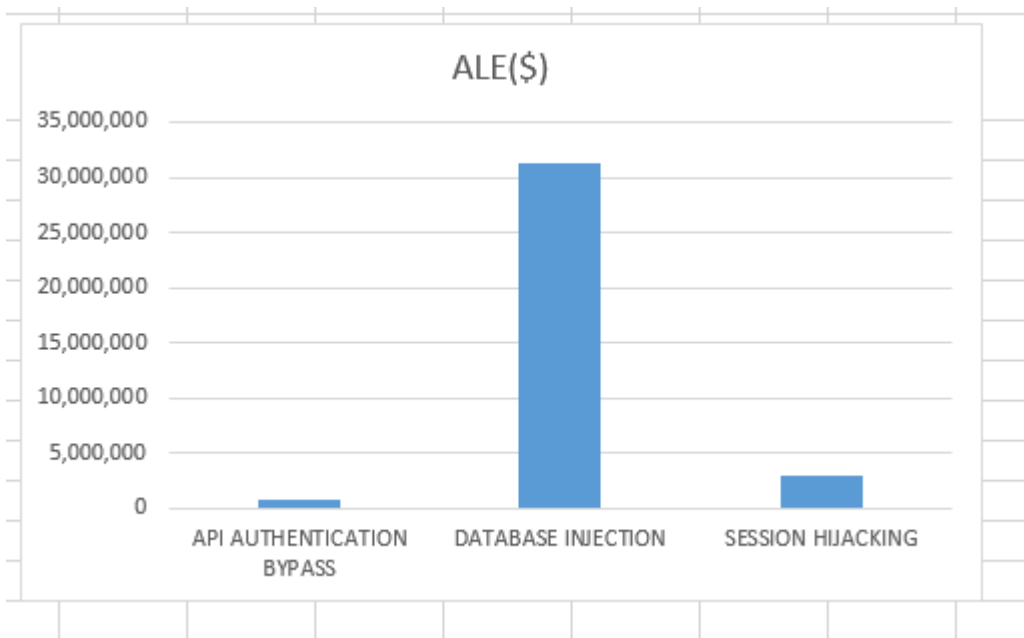
Vulnerability	SLE (\$)	ARO	ALE(\$)	Likelihood (1-5)	Impact (1-5)	SCORE	LEVEL
API AUTHENTICATION BYPASS	5,000,000	0.15	750,000	LOW(2)	LOW(1)	2	Low
DATABASE INJECTION	125,000,000	0.25	31,250,000	MEDIUM(2)	CRITICAL(5)	10	High
SESSION HIJACKING	7,500,000	0.40	3,000,000	MEDIUM(3)	MEDIUM(2)	6	Medium

Task 3: Create Risk Visualization

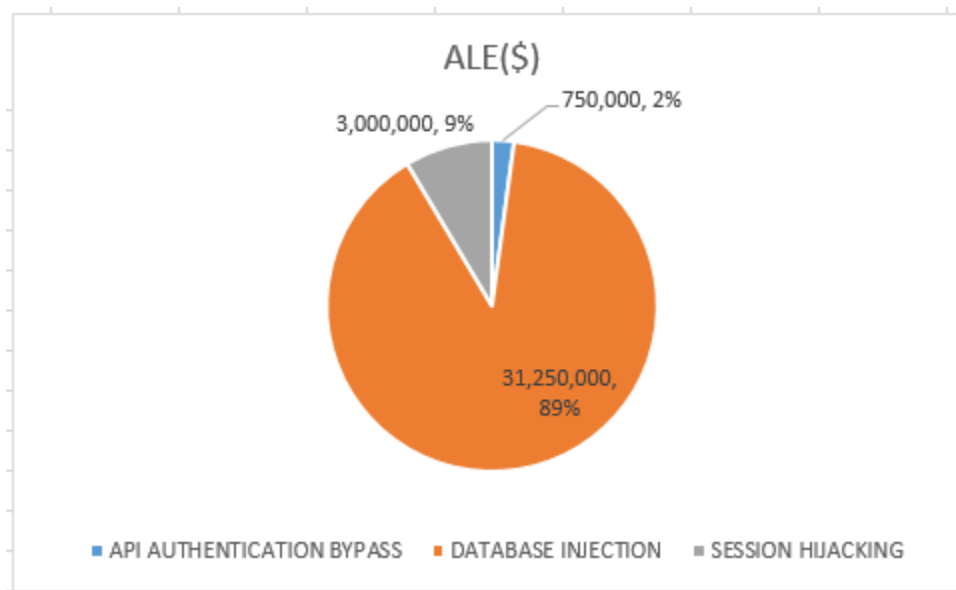
ANSWER: This requirement was developed in Excel and Screenshot Captured for All The requirements in This task

Vulnerability	Vulnerability	ALE(\$)
	API AUTHENTICATION BYPASS	750,000
	DATABASE INJECTION	31,250,000
	SESSION HIJACKING	3,000,000
	ALE	

- Generate a bar chart comparing ALE for all vulnerabilities

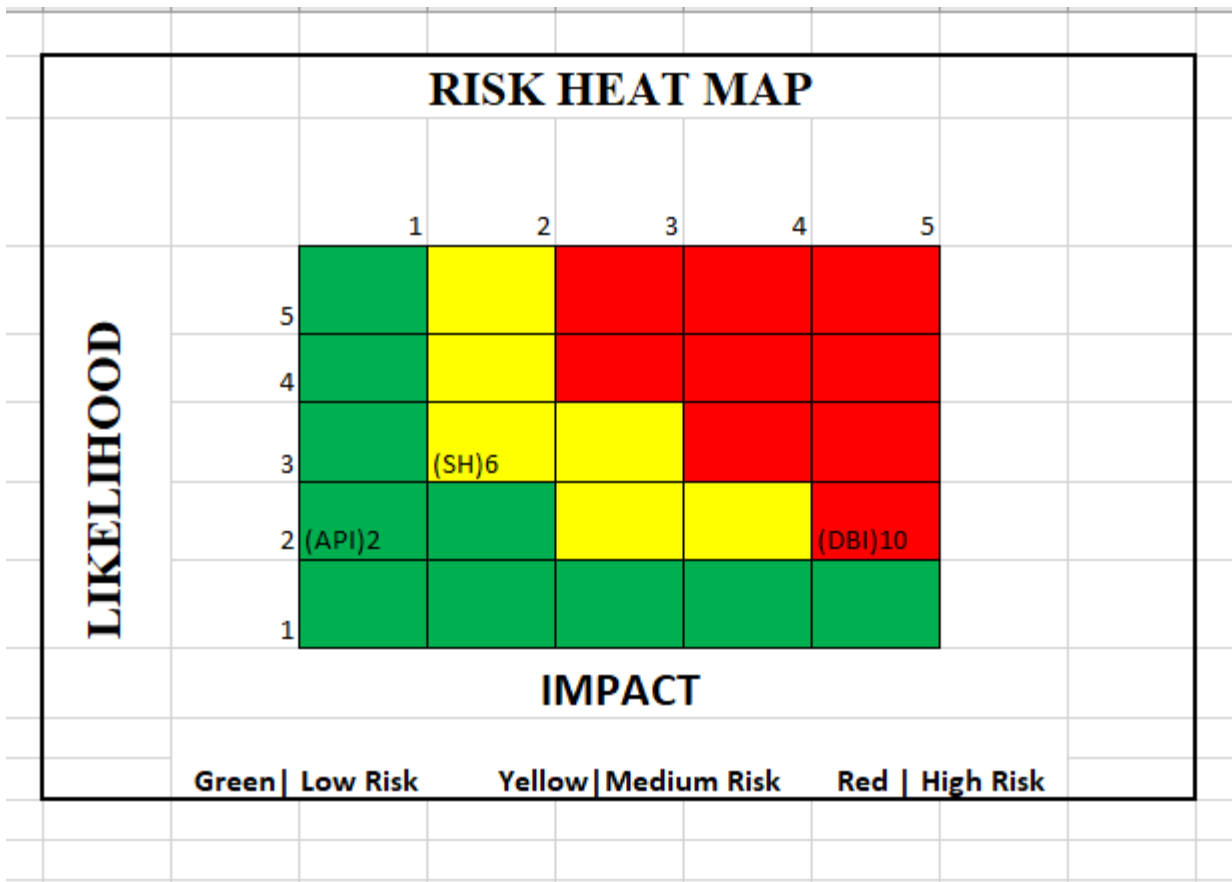


- Create a pie chart showing risk distribution



- **Develop a risk heat map (High/Medium/Low) based on probability and impact**

This was adopted using the Risk Matrix, getting the score and mapping as shown below:



Phase 2: Control Evaluation

Task 4: Cost-Benefit Analysis

For each control option, calculate:

- Initial Investment
- Annual Maintenance
- Risk Reduction (in \$)
- Return on Investment (ROI)
- Payback Period

ANSWER:

1. Advanced API Security Gateway

- Initial Investment=Cost: \$350,000
- Effectiveness: 90% reduction in API vulnerabilities
- Annual Maintenance: \$50,000/year
- ALE ORIGINAL= \$750,000

- e. RISK REDUCTION= $750,000 \times 0.90 = \$675,000$
- f. ROI= $(675,000 - (350,000 + 50,000)) / (350,000 + 50,000) = 275,000 / 400,000 = 68.75\%$
- g. PAYBACK PERIOD= INITIAL COST/RISK REDUCTION= $350,000 / 675,000 = \sim 0.52$
Years X 365 DAYS=189.8 DAYS

2. Web Application Firewall (WAF)

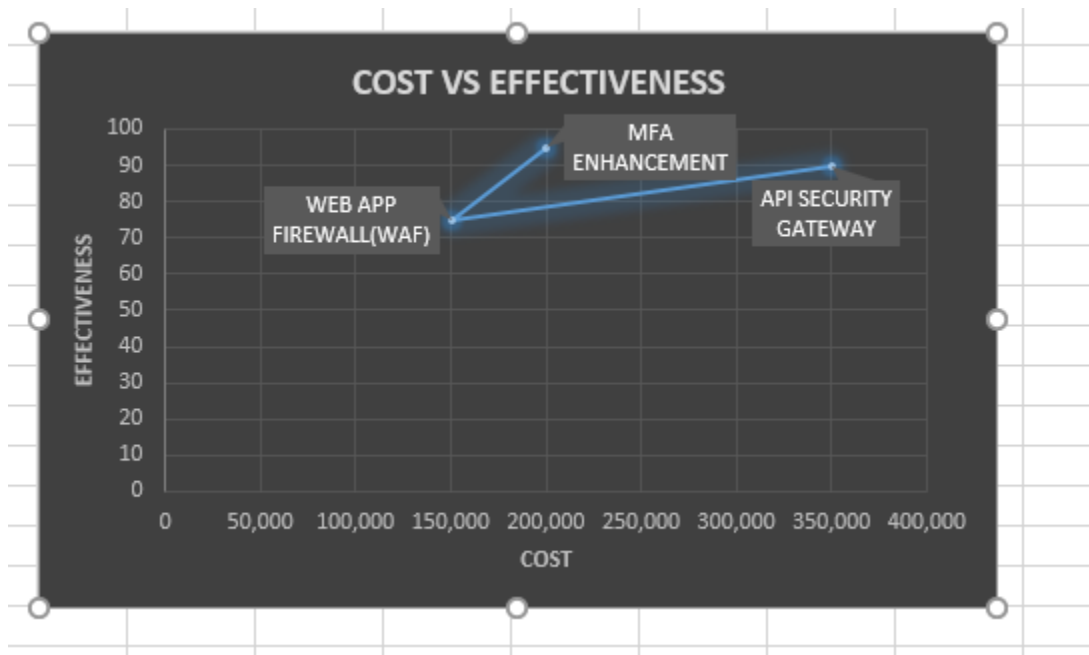
- a. Cost: \$150,000
- b. Effectiveness: 75% reduction in web vulnerabilities
- c. Maintenance: \$25,000/year
- d. ALE ORIGINAL: \$31,250,000
- e. RISK REDUCTION= $31,250,000 \times 0.75 = \$23,437,500$
- f. ROI= $(23,437,500 - (150,000 + 25,000)) / (150,000 + 25,000)$
 $= 23,262,500 / 175,000 = 13,292.86\%$
- g. PAYBACK PERIOD= $150,000 / 23,437,500 = \sim 0.0064$ YEARS X 365 DAYS= 2.3 DAYS

3. Multi-Factor Authentication Enhancement

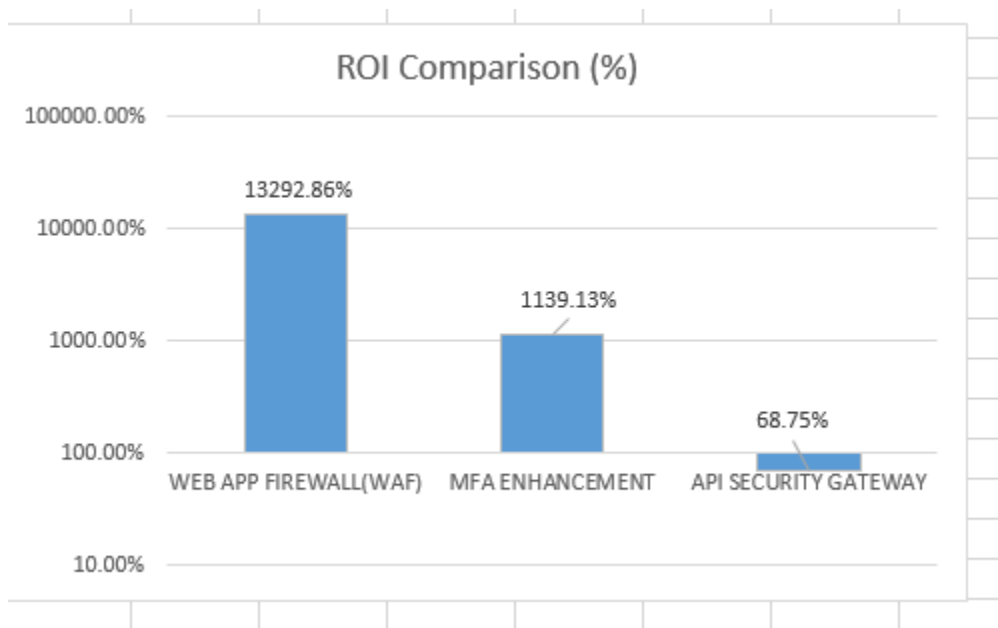
- a. Cost: \$200,000
- b. Effectiveness: 95% reduction in account takeover
- c. Maintenance: \$30,000/year
- d. ALE=\$3,000,000
- e. RISK REDUCTION= $\$3,000,000 \times 0.95 = \$2,850,000$
- f. ROI= $(2,850,000 - (200,000 + 30,000)) / (200,000 + 30,000)$
 $= 2,620,000 / 230,000 = 1,139.13\%$
- g. PAYBACK PERIOD: $200,000 / 2,850,000 = 0.0701$ YEARS x 365 DAYS= ~25.6 DAYS

Task 5: Control Selection Analysis

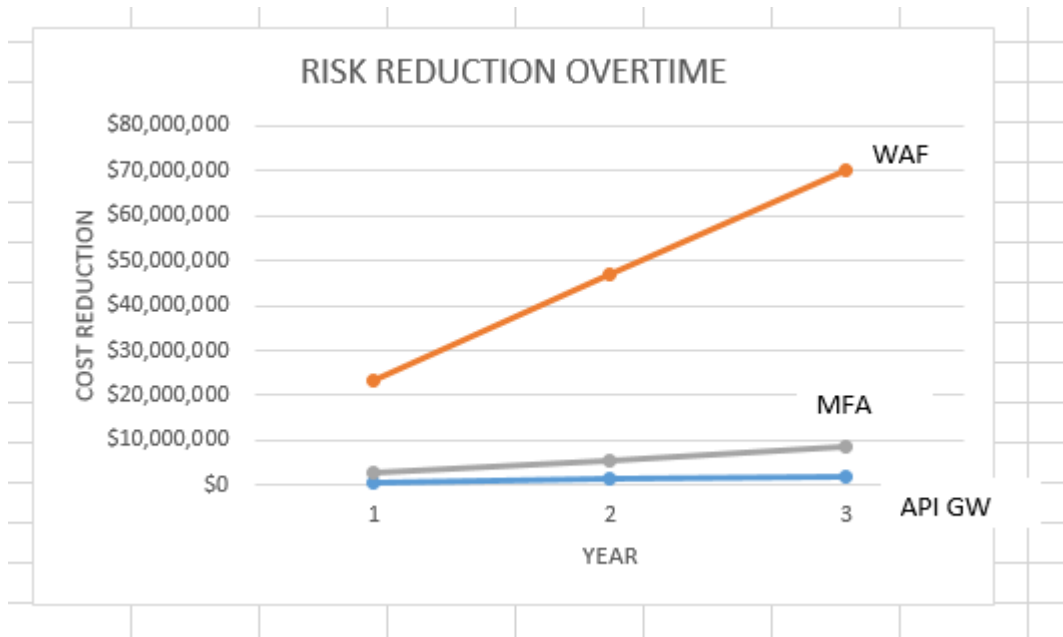
- Create a scatter plot showing cost vs. effectiveness of controls



- **Generate a bar chart comparing ROI for all controls**
- Note: A logarithmic scale was applied to the ROI comparison chart for clearer visual representation and relative comparison and to avoid distortion caused by the extreme outliers.



- **Develop a line graph showing risk reduction over time**
- ASSUMPTION: Risk Reduction stays constant per year, no changes on effectiveness, projected a three-year period



Phase 3: Executive Reporting

Task 6: Create Executive Dashboard

EXECUTIVE REPORTING

Comprehensive Executive Briefing

To: Board of Directors, CISO, CFO

From: GRC Risk Analysis Team

Date: 04/10/2025

Subject: Analysis: Penetration Test And Vulnerability Assessment New Mobile Banking Platform

1. Executive Summary:

As the lead Analyst at SecureBank Financial, together with my team, we conducted a quantitative risk assessment that identified three critical risks with high financial, regulatory and reputational impact. Using Annualized Loss Expectancy (ALE) and Annual Rate of Occurrence (ARO), risks were prioritized by likelihood and impact. The most critical was a database injection issue with an annual exposure of over \$31 Million.

A cost-benefit analysis was performed for the proposed three controls:

- Web Application Firewall (WAF)
- Multi-Factor Authentication (MFA)
- API Security Gateway.

In the sections below we present different analysis, tables charts and graphs to support our recommendations and provide the Risk Treatment Plan.

- **Top 3 risks with financial impact**

The table outlines the top 3 risks currently presented in our analysis with the highest ranked risk as the database injection as shown in the table below adjacent to the vulnerability is the Annual Loss Expectancy attached to the type of vulnerability.

RANK	VULNERABILITY	ALE(\$)
1	Database Injection	\$31,250,000
2	Session Hijacking	\$3,000,000
3	API Authentication Bypass	\$750,000

- **Recommended controls with costs**

Given the critical risks and the impact to the financial, reputational and regulatory standing, we have analyzed proposed risk as below with the initial cost and Annual Maintenance Cost(AMC) Factored.

Control	Initial Cost	Annual Maintenance
Web App Firewall (WAF)	\$150,000	\$25,000
MFA Enhancement	\$200,000	\$30,000
API Security Gateway	\$350,000	\$50,000

- **Expected risk reduction and ROI calculations**

Below table outline our expected annual risk reduction post control implementation and the Return on Investment. The **WAF** has the **highest ROI**:

Control	Annual Risk Reduction	ROI (%)
Web App Firewall (WAF)	\$23,437,500	13,292.86%
MFA Enhancement	\$2,850,000	1,139.13%
API Security Gateway	\$675,000	68.75%

Visualizations:

- **Risk exposure before/after controls (double bar chart)**

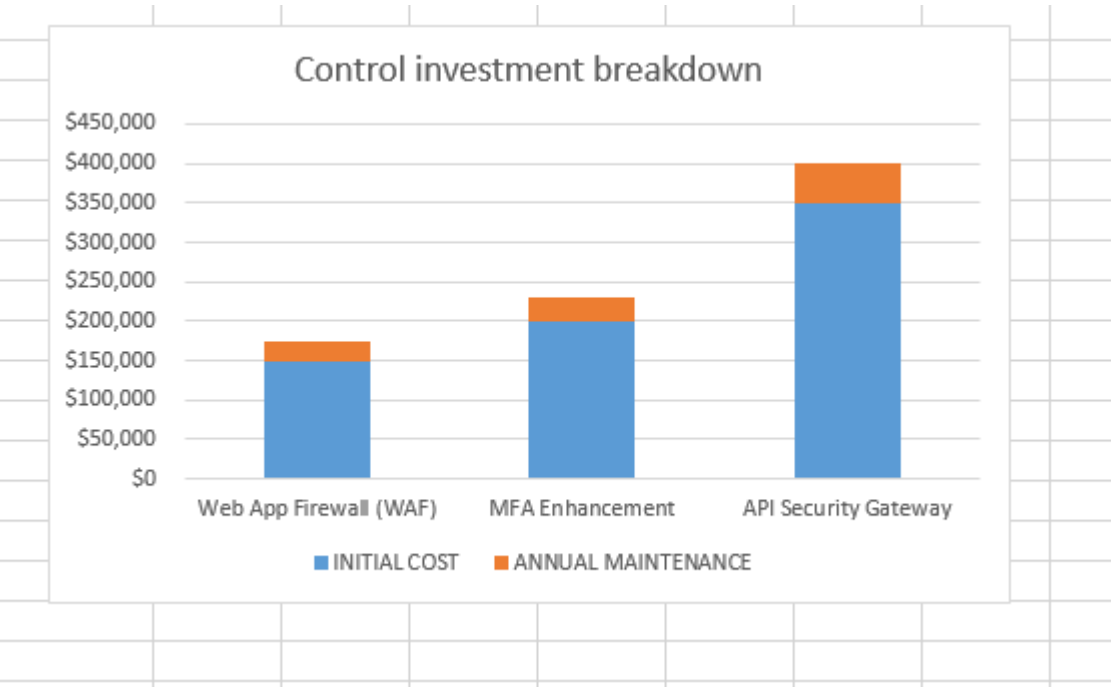
To get the Risk Exposure After (New ALE), we established by reducing the ALE by the effectiveness of the control; e.g. for the API Security effectiveness 90% so the residual will be a 10% new ALE= $ALE * 0.1 = (\$750,000 \times 0.1) = \$75,000$.

The below chart shows the comparison of before and after applying the proposed control.



- Control investment breakdown (stacked bar chart)**

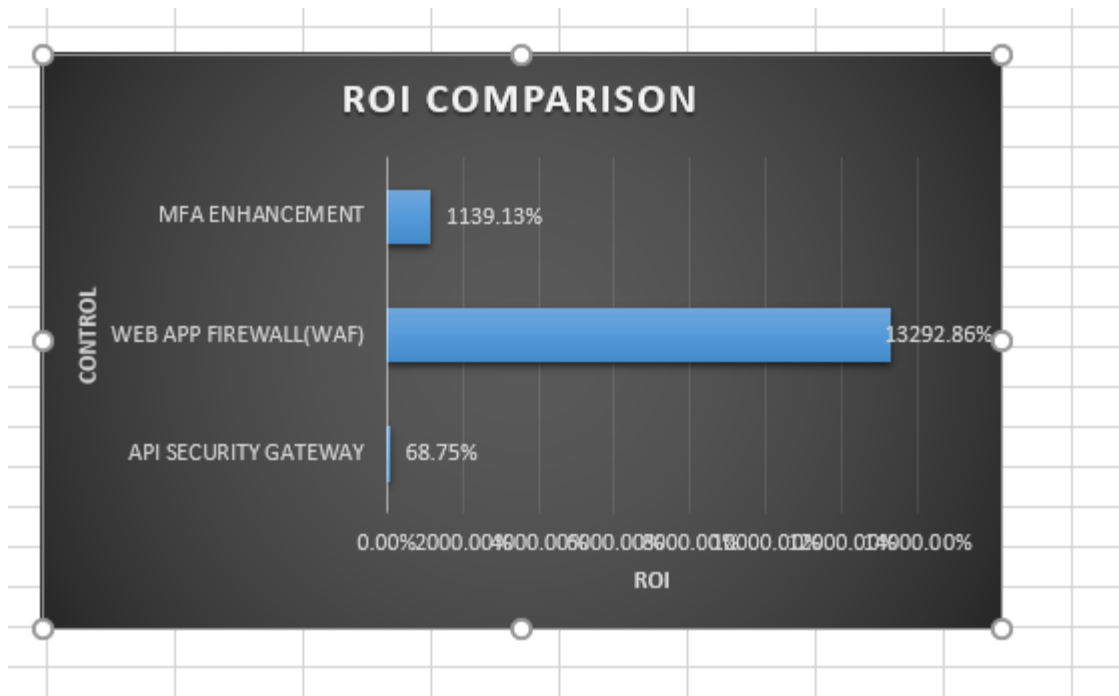
The cost of the investment breakdown is equal to the cost of the control+ the AMC. The chart below shows the total cost in the first year of investment:



- **ROI comparison across controls (horizontal bar chart)**

We refer to the chart below to have a view of the ROI per control proposed.

Note: A linear scale was retained in the chart to maintain simplicity and readability. While this translates to some smaller values appearing less prominent, it preserves the true scale of return and more suitable for non-technical stakeholders.



Task 7: Risk Treatment Timeline

Create a Gantt chart showing:

Answer: We proposed the risk treatment Plan below, based on urgency, complexity and strategic implementation factoring in elements e.g. configurations and integration and long term strategy etc., and the key Inputs and actions are categorized as below

- **Immediate actions (first 30 days)**

Patch Vulnerabilities Identified (~ 15 days)

Deployment of WAF (30 days)

- **Short-term controls (90 days)**

Implementing MFA Enhancement (60 days)

Deploy API Security Gateway (60 Days)

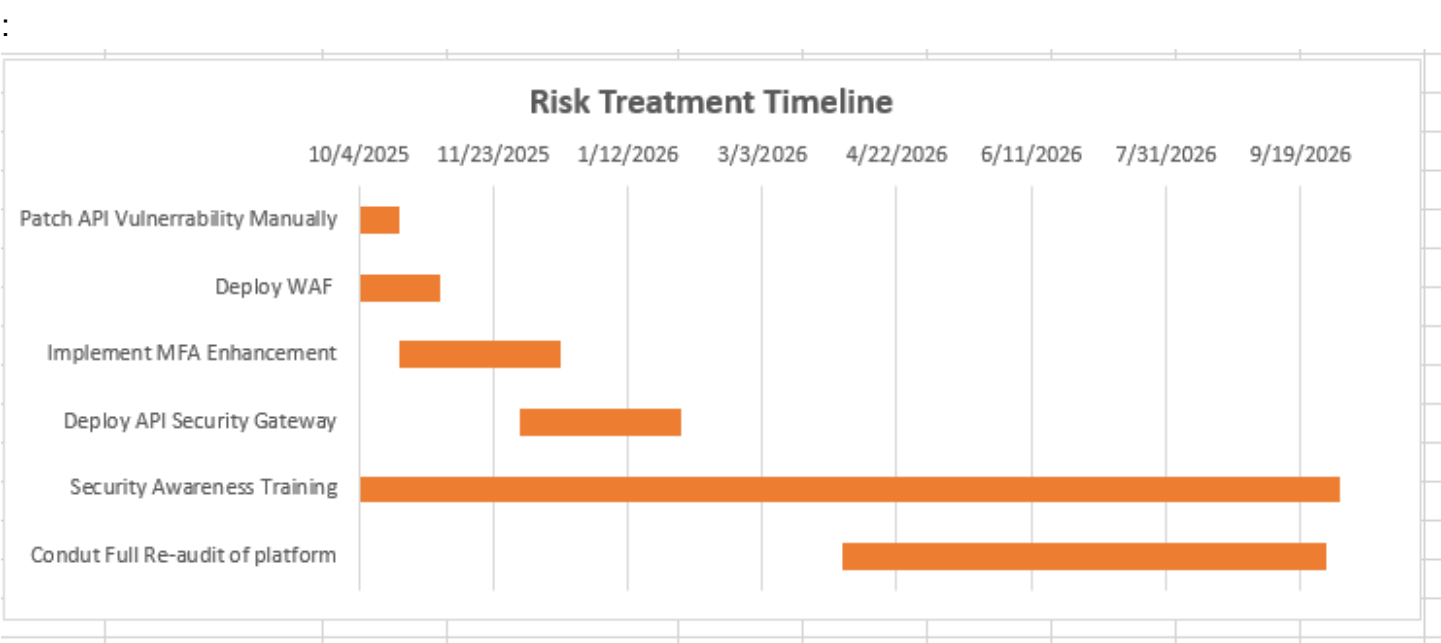
- **Long-term strategy (1 year)**

Staff Security Awareness Training (continuous)

Platform Re-Audit (To start after Controls and Trainings and continue for 180 days)

Gantt chart:

We summarize our risk treatment plan using the visual below showing the tasks planned and the projected kickoff and completion timelines.



- **Current risk exposure vs. residual risk after controls**

The table below highlights the risk exposure before and after proposed controls:

Control	Current Risk Exposure	Residual Risk Exposure
Web Application Firewall	\$31,250,000	\$7,812,500
MFA Enhancement	\$3,000,000	\$150,000
API Security Gateway	\$750,000	\$75,000

- **Control cost vs. risk reduction benefit**

The Table below shows a summary of the cost vs benefit of proposed control.

Control	Control Cost(Initial + AMC)	Risk Reduction Benefit (Initial ALE-Residual ALE)
Web Application Firewall	\$175,000	\$23,437,500
MFA Enhancement	\$230,000	\$2,850,000
API Security Gateway	\$400,000	\$675,000

- **Optimal control selection based on budget constraints**

Given no budget constraint amount was provided, we will base our analysis based on the table previously given, table above which indicated the control cost vs the risk reduction benefit, as shown, The **Web Application Firewall** provides **the highest risk reduction benefit for the lowest cost**, making it the **most cost efficient control**. The MFA Enhancement also offers a balance between the cost and risk reduction. The API Security Gateway, while also effective, is costlier as compared to the risk reduction offered. Therefore, prioritizing controls like the WAF and MFA Enhancement will maximize risk mitigation per investment made. In addition to the cost vs benefit parallel, the WAF mitigates a critical DB Injection vulnerability which affects sensitive customer data and carries significant risks in terms of financial, regulatory and reputational.